Security Assessment & Threat Intelligence Report

Target: **httpbin.org** • Audit Date: **2026-10-22 09:58:39**

1. Executive Summary

Target URL	`https://httpbin.org`	**Overall Posture Score**	**67/100** (Grade D)
Resolved IP	`100.56.179.159`	**Total Findings**	**7** items identified
Audit Status	Completed	**Scan Duration**	116.55 seconds

Critical	High	Medium	Low	Informational
0	0	3	3	1

2. Reconnaissance & Fingerprinting

HTTP Status	200
Page Title	httpbin.org
Server Header	`gunicorn/19.9.0`
HTTPS / TLS	TLSv1.2 (Issuer: Amazon - Amazon RSA 2048 M01, Expiry: 2027-01-02 23:59 UTC)
Detected Tech	gunicorn/19.9.0

3. Detailed Security Configuration Findings

#1. Missing Content-Security-Policy (CSP) Header — [MEDIUM] • HTTP Security Headers

Evidence:	`Header 'Content-Security-Policy' is absent from the HTTP response.`
Why it matters:	Content-Security-Policy restricts the sources from which scripts, styles, images, and other resources can be loaded. Without a CSP header, the browser cannot prevent unauthorized script execution, leaving the site more susceptible to Cross-Site Scripting (XSS) and data injection.
Remediation:	Configure a Content-Security-Policy header defining trusted sources. Example: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none';

#2. Missing HTTP Strict Transport Security (HSTS) Header — [MEDIUM] • Transport Security

Evidence:	`Header 'Strict-Transport-Security' is absent from the HTTPS response.`
Why it matters:	HSTS forces compatible browsers to interact with the domain exclusively over HTTPS. Without HSTS, the initial connection or any HTTP bookmark can be intercepted via SSL-stripping Man-in-the-Middle (MitM) attacks.
Remediation:	Enable HSTS on your web server with an adequate max-age duration (e.g., at least 1 year). Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

#3. Missing X-Content-Type-Options Header	[LOW] • HTTP Security Headers
Evidence:	`Header 'X-Content-Type-Options' is absent.`
Why it matters:	The X-Content-Type-Options header instructs the browser not to 'sniff' or guess MIME types different from what the server declared. Without this header, non-executable files (like images) might be interpreted as HTML/JavaScript if malicious code is embedded within them.
Remediation:	Add the following response header: X-Content-Type-Options: nosniff

#4. Missing Clickjacking Protection (X-Frame-Options / frame-ancestors)	[MEDIUM] • HTTP Security Headers
Evidence:	`Neither 'X-Frame-Options' nor CSP 'frame-ancestors' directive was detected.`
Why it matters:	Clickjacking attacks trick users into clicking invisible or disguised UI elements by embedding the vulnerable website inside an invisible iframe on a malicious third-party site.
Remediation:	Configure clickjacking defenses using either: X-Frame-Options: DENY (or SAMEORIGIN) Or in CSP: frame-ancestors 'self';

#5. Missing Referrer-Policy Header	[LOW] • HTTP Security Headers
Evidence:	`Header 'Referrer-Policy' is absent from the HTTP response.`
Why it matters:	When a user clicks a link to an external website, the browser sends the current page URL in the 'Referer' header. Without a strict Referrer-Policy, sensitive parameters (such as tokens, session identifiers, or private user IDs in query strings) may leak to third parties.
Remediation:	Set a privacy-preserving Referrer-Policy header: Referrer-Policy: strict-origin-when-cross-origin

#6. Missing Permissions-Policy Header	[INFORMATIONAL] • HTTP Security Headers
Evidence:	`Header 'Permissions-Policy' is absent.`
Why it matters:	Permissions-Policy allows site owners to explicitly restrict which browser hardware features and APIs (e.g. camera, microphone, geolocation, payment) can be accessed by the page or embedded iframes.
Remediation:	Add Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()

#7. Server Banner Information Disclosure ('gunicorn/19.9.0')	[LOW] • Information Disclosure
Evidence:	`Server header reveals exact software version: 'gunicorn/19.9.0'.`
Why it matters:	Exposing exact web server software versions helps attackers identify specific, known CVEs or unpatched vulnerabilities targeting that release.
Remediation:	Configure the web server to suppress detailed version banners: - Nginx: server_tokens off; - Apache: ServerTokens Prod; ServerSignature Off;

4. Authorized Port & Service Discovery

Port scanning was disabled or not authorized for this scan session.

5. Threat Intelligence Records

Intelligence Source	Status	Match Category	Details
Google Safe Browsing v4	API Key Not Configured	None	Google Safe Browsing API key not set. To enable this lookup, obtain a free API key from Google Cloud Console and set SAFE_BROWSING_API_KEY in your .env file.
abuse.ch URLhaus Threat Feed	HTTP Error 401	None	Could not complete lookup with URLhaus endpoint.
Static Threat & Heuristic Indicators	Completed	None	No records

6. AI-Assisted Security Analysis & Remediation Roadmap

*AI Engine: **Builtin** • Note: AI-synthesized findings are advisory explanations and should be validated by human analysts.*

Executive Security Summary for httpbin.org

The automated assessment of httpbin.org yielded an overall Security Posture Score of 67/100 (Grade: D).

Recommended Hardening Measures There are 3 medium-severity configuration gap(s), primarily around defensive HTTP headers: - Missing Content-Security-Policy (CSP) Header: Content-Security-Policy restricts the sources from which scripts, styles, images, and other resources can be loaded. Without a CSP header, the browser cannot prevent unauthorized script execution, leaving the site more susceptible to Cross-Site Scripting (XSS) and data injection. - Missing HTTP Strict Transport Security (HSTS) Header: HSTS forces compatible browsers to interact with the domain exclusively over HTTPS. Without HSTS, the initial connection or any HTTP bookmark can be intercepted via SSL-stripping Man-in-the-Middle (MitM) attacks. - Missing Clickjacking Protection (X-Frame-Options / frame-ancestors): Clickjacking attacks trick users into clicking invisible or disguised UI elements by embedding the vulnerable website inside an invisible iframe on a malicious third-party site.

Transport Security (SSL/TLS) The site establishes HTTPS using TLSv1.2 with cipher suite ECDHE-RSA-AES128-GCM-SHA256. The certificate was issued by Amazon - Amazon RSA 2048 M01 and is valid until 2027-01-02 23:59 UTC (72 days remaining).

Educational Takeaway for Project Demonstration Modern web security relies on 'Defense-in-Depth'. Security headers (such as CSP, HSTS, and X-Content-Type-Options) cost nothing in computing overhead but provide crucial protection against modern client-side attacks like Cross-Site Scripting (XSS), Clickjacking, and SSL-Stripping. Implementing these recommended headers is the single highest ROI security enhancement for web applications.

7. Audit Limitations & Methodology Notice

Important Academic & Audit Disclaimer: This security assessment is based exclusively on non-destructive passive observations, observable HTTP headers, TLS certificate negotiation, and authorized port probing. The calculated risk score is a comparative prioritization tool, NOT a guarantee of safety or freedom from vulnerabilities. External threat intelligence queries reflect available database feeds at the time of execution. This tool is designed strictly for educational and authorized defensive auditing.